



AI Banking Resources · Template

AI Use Policy Starter

A starter policy your team can adapt in an afternoon. Defines allowed tools, allowed data, review requirements, and an incident path.

For: Compliance, risk, and senior management 8 min

PURPOSE

This policy governs how staff at [Institution] use generative AI tools in the course of work. It applies to any tool that takes free-text input and returns generated text, images, or code — whether vendor-hosted (e.g., Claude, ChatGPT, Gemini), embedded in a vendor product, or self-hosted.

ALLOWED TOOLS

Only AI tools on the approved list may be used for institution work. The approved list is maintained by [Owner role] and reviewed at minimum quarterly.

Tools on the approved list have a signed vendor agreement covering data handling.

Personal accounts on consumer AI services are prohibited for any institution data.

A tool moves to the approved list only after Compliance and InfoSec sign-off.

ALLOWED DATA

Inputs to AI tools follow the institution's data classification scheme. Use this as a starting matrix and adjust per your policies:

Public information: allowed without restriction.

Internal information (procedures, drafts, summaries): allowed in approved tools only.

Confidential (customer data, NPI, account details, transaction data): not permitted in any AI tool unless the vendor agreement explicitly covers it and the tool runs in an approved private deployment.

Regulated data (BSA/AML detail, SARs, loan decisioning rationale, examination work product): not permitted.

HUMAN-IN-THE-LOOP REQUIREMENT

AI outputs are draft work product. Every artifact that touches a customer, an examiner, or a regulated process requires documented human review before use.

The reviewer is identified by name and role on the artifact.

The reviewer attests that they verified factual claims, calculations, and any regulatory references.

Review evidence is retained for the period defined by [Institution]'s records retention schedule.

DOCUMENTATION

For AI-assisted work that produces a customer-facing or examiner-relevant artifact, staff document:

- Which approved tool was used.
- The prompt or instruction provided.
- The data class of the input.
- The human reviewer and date of review.

INCIDENTS

Suspected policy violations, prompt injections, model misuse, or accidental disclosure of regulated data follow the institution's existing incident response procedure with one addition:

- Notify [Compliance owner] and [InfoSec owner] within 24 hours of discovery.
- Preserve the prompt, output, and any downstream artifacts for review.
- Do not delete tool history while the incident is open.

REVIEW CYCLE

This policy is reviewed at minimum annually and on any of the following triggers:

- A new tool is added to the approved list.
- A regulator issues new AI-specific guidance applicable to the institution.
- An incident review surfaces a policy gap.

SOURCED FROM

AIEOG AI Lexicon — US Treasury / FBIIC / FSSCC, Feb 2026
SR 11-7 Model Risk Management Guidance
Interagency TPRM Guidance

Get new templates when they ship

ADAPT BEFORE ADOPTING

These are starters — not final policy.

Every template names a section your institution should change. Bring it to your committee, your auditor, and your examiner before adoption.

[Browse more resources](#)

[Take the readiness assessment](#)